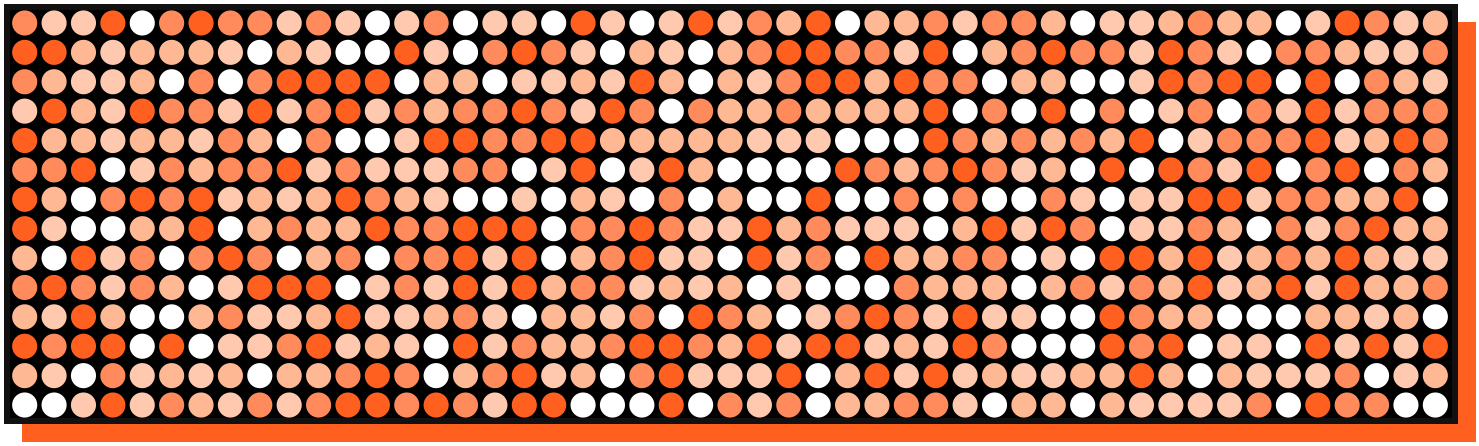
PAPYRUS EVIDENCE PACK

SUPPLY-CHAIN EVIDENCE

Image digests, signatures, build provenance, SBOMs and vulnerability scans for this release.



RELEASE	BUILT
0.1.0+fd55e38	2026-10-20T13:03:06Z
IMAGE	**INDEX DIGEST**
ghcr.io/beaglabs/papyrus/papyrus	sha256:b38facf4950270443ac39dc5bbaeb4ed5653341b6160852 6163e929a449ebd8a

Prepared by Beag Labs from the Papyrus source and its published release image. Describes the software and the responsibilities it leaves to a deploying organization. It is not a certification, an authorization or a third-party assessment.

CONTAINER SUPPLY-CHAIN EVIDENCE

Evidence for the published Papyrus image `ghcr.io/beaglabs/papyrus/papyrus@sha256:b38facf4950270443ac39dc5bbaeb4ed5653341b61608526163e929a449ebd8a`, built from revision `fd55e3821fda9edf4c1519da6767f6f8240695fa` on 2026-10-20T13:03:06Z. Every item below was produced or checked by tools against that digest; the commands to repeat each check are at the end.

IMAGE

PLATFORM	MANIFEST DIGEST	CREATED	USER	LAYERS	SBOM COMPONENTS
linux/amd64	`sha256:d8e4eef2f369904f78c221557f0658ccc99e66f2c742e4ca183ca6f48100ee62`	2026-10-20T13:03:06.693559365Z	nonroot	22	2002
linux/arm64	`sha256:d042fb61f607e061c24f4cf37a08aa0a824cf27357a67f147b500534e1ba224b`	2026-10-20T13:29:11.564833442Z	nonroot	22	2002

SIGNATURE

The multi-arch index is signed keylessly with Sigstore cosign by GitHub Actions and recorded in the Sigstore public-good Rekor transparency log. Verification passed for workflow identity `^https://github\.com/beaglabs/papyrus/\.github/workflows/container(-multiarch)?\.yml@refs/heads/main$` from issuer `https://token.actions.githubusercontent.com`, at workflow revision `fd55e3821fda9edf4c1519da6767f6f8240695fa` on `refs/heads/main`.

BUILD PROVENANCE

A `https://slsa.dev/provenance/v1` attestation for the index digest was verified: signed by `https://github.com/beaglabs/papyrus/.github/workflows/container.yml@refs/heads/main` on a github-hosted runner from source `fd55e3821fda9edf4c1519da6767f6f8240695fa`. The source repository is private, so the attestation is signed through GitHub Sigstore (private repository); the Sigstore bundle is published in this pack so it can be verified without repository access.

VULNERABILITY SCAN

Scanned with Trivy 0.72.0 using the vulnerability database updated 2026-10-22T13:15:26.425424764Z. Counts are findings, with the number that have a fixed version available in brackets. A scan is a point-in-time result; rescan the digest for current findings.

PLATFORM	CRITICAL	HIGH	MEDIUM	LOW
linux/amd64	0 (0)	25 (21)	26 (25)	4 (4)
linux/arm64	0 (0)	25 (21)	26 (25)	4 (4)

SOFTWARE BILL OF MATERIALS

Each platform has a CycloneDX and an SPDX SBOM generated from the image itself, so they include operating system packages and every transitive Node.js and Python dependency in the shipped filesystem. Timestamps and serial numbers are pinned to the image so repeated runs produce identical documents.

HOW TO VERIFY

SIGNATURE (COSIGN 2.4+)

```
cosign verify --certificate-identity-regexp '^https://github\.com/beaglabs/papyrus/\.github/workflows/container(-multiarch)?
\.yml@refs/heads/main$' --certificate-oidc-issuer https://token.actions.githubusercontent.com
ghcr.io/beaglabs/papyrus/papyrus@sha256:b38facf4950270443ac39dc5bbaeb4ed5653341b61608526163e929a449ebd8a
```

PROVENANCE (GITHUB CLI 2.60+, RUN FROM THIS PACK'S FOLDER)

```
gh attestation verify oci://ghcr.io/beaglabs/papyrus/papyrus@sha256:b38facf4950270443ac39dc5bbaeb4ed5653341b61608526163e929a449ebd8a --bundle
supply-chain/provenance.sigstore.json --repo beaglabs/papyrus
```

SBOM AND SCAN (TRIVY)

```
trivy image --format cyclonedx ghcr.io/beaglabs/papyrus/papyrus@<platform digest>
```

FILES

FILE	SHA-256
sbom/papyrus-linux-amd64.cdx.json	8d8dcdd7876ab1e253f6db5263745eb4c5d27b63dbde60e1c314f70f4b6a242c
sbom/papyrus-linux-amd64.spdx.json	13a8f38684567d5f4b02fc6369b323f3a6903f0537268a5f97cc8f4c522ccfa4
sbom/papyrus-linux-arm64.cdx.json	4c6f5548118b38901db82d594e8c860cad16f9fa65e145fe97cb72200647d8cc
sbom/papyrus-linux-arm64.spdx.json	92cb96d55082a1e1bcc791822bd03ba99f8f87dc74538c47ebb6d26fed09f168
supply-chain/image-index.json	2adf3fbe144a427bfcc6cbc42ebb910df8068e1fd0e545054a7543e998d579c9
supply-chain/provenance-verification.json	49d7598b0860155151fccce8a3e2030b76d8556b6cc76b8e4a992bca179f9177
supply-chain/provenance.sigstore.json	fb8d9008e2481a2c078c318c4e6683d7d08579a8b3ad0b46f2359589782e521e
supply-chain/signature-verification.json	a7985f95730cbb76f4e98abaa640e8948c81e902f715d9d73191ccd39b38bacc
supply-chain/vulnerabilities-linux-amd64.json	bb5db34ec8829a086d0cc6075fc630fd47dc7848a448bdc552a9fcaf7a1ddd0d
supply-chain/vulnerabilities-linux-arm64.json	d27561ef3ac7414e982058d4fda43c9d06152f41896e9c2a0caded3837cea47c